

RESUMEN ESQUEMA NACIONAL DE SEGURIDAD Y SEGURIDAD 5G

Marco Normativo y Fundamentos del ENS (RD 311/2022)	1
Los Siete Principios Básicos del ENS	2
Los 15 Requisitos Mínimos de Seguridad	3
Categorización de Sistemas y Dimensiones de Seguridad	4
Estructura de Medidas de Seguridad (Anexo II)	4
El Esquema Nacional de Seguridad 5G (ENS5G) – RD 443/2024	
Elementos Críticos y Gestión de Riesgos en Redes 5G	5
Suministradores de Alto Riesgo y Estrategia de Diversificación ...	6
Gobernanza y Respuesta a Incidentes 5G	6
Glosario de Términos Imprescindibles	7

Marco Normativo y Fundamentos del ENS (RD 311/2022)

Concepto Clave: El Esquema Nacional de Seguridad (ENS) no es una recomendación; es el marco obligatorio que garantiza la seguridad de la información en la Administración. Su objeto es establecer principios básicos, requisitos mínimos y medidas de seguridad proporcionales.

Ámbito de aplicación: Obligatorio para todo el Sector Público y entidades privadas que presten servicios a las Administraciones.

¡OJO! EXCEPCIÓN: El ENS5G (RD 443/2024), en su Art. 4.2, excluye explícitamente las actividades de Defensa Nacional, Seguridad Nacional, Seguridad Pública y cumplimiento de la ley (investigación penal).

Objetivos principales:

- **Confianza en medios electrónicos:** Crear un entorno seguro para ciudadanos y Administración.
- **Seguridad común:** Establecer niveles de protección uniformes.

- **Resiliencia:** Capacidad de prevención, detección, respuesta y recuperación.
- **Interoperabilidad:** Garantizar el intercambio seguro de datos.

Plazo de adecuación: Las Administraciones tienen un periodo de 24 meses para adecuarse al nuevo ENS tras su publicación.

Autoevaluación (Categoría Básica): Los sistemas de categoría básica deben realizar una autoevaluación al menos cada dos años (24 meses) o cuando haya cambios sustanciales.

Los Siete Principios Básicos del ENS

Principio	Descripción Clave para Examen
Seguridad integral	Proceso constituido por elementos humanos, técnicos, materiales y organizativos.
Gestión de riesgos	Análisis permanente para mantener riesgos en niveles aceptables. Actividad continua.
Prevención, detección, respuesta y recuperación	Minimizar vulnerabilidades para que las amenazas no afecten a la operatividad. TLS (Transport Layer Security): La versión mínima aceptable es la 1.2 y la recomendada es la 1.3 Puerto 80 (HTTP): El CCN recomienda no cerrarlo, sino configurar el servidor para que realice una "redirección automática de HTTP (80) a HTTPS (443)"
Líneas de defensa	Defensa en profundidad con capas organizativas, físicas y lógicas.
Vigilancia continua	Monitorización para detectar actividades anómalas en tiempo real.
Reevaluación periódica	Actualización según la evolución de amenazas. Obligatoria para no perder eficacia.
Diferenciación de responsabilidades	Pregunta de Examen: Debe haber separación clara entre el Responsable de

	la Información (determina requisitos), el del Servicio (determina requisitos de servicio) y el de Seguridad (implanta las medidas).
--	---

Los 15 Requisitos Mínimos de Seguridad

Para un sistema ENS, estos 15 puntos son el "mínimo común denominador" exigible:

- 1. Organización de la seguridad**
Estructura clara de funciones y responsabilidades (Gobernanza).
- 2. Gestión de la seguridad basada en los riesgos**
Obligación de análisis de riesgos continuo y documentado.
- 3. Gestión del personal**
Formación y concienciación. El personal debe conocer sus deberes y obligaciones.
- 4. Profesionalidad**
La seguridad debe ser gestionada por personal con cualificación técnica acreditada.
- 5. Autorización y control de accesos**
Limitación estricta basada en el concepto de "necesidad de conocer".
- 6. Protección de las instalaciones**
Seguridad física de los perímetros y centros de proceso de datos.
- 7. Adquisición de productos y contratación de servicios**
Asegurar que los terceros cumplen los mismos niveles de seguridad.
- 8. Mínimo privilegio**
El usuario solo tiene acceso a lo estrictamente necesario para su función.
- 9. Gestión de la configuración**
Control total sobre los cambios en hardware y software.
- 10. Seguridad por defecto**
Los sistemas deben venir configurados con el máximo nivel de protección de fábrica.
- 11. Integridad y actualización del software**
Garantía de software legítimo y siempre parcheado.
- 12. Gestión de incidentes**

Procedimientos de notificación y respuesta ante brechas de seguridad.

13. Registro de actividad (log)

Trazabilidad de todas las acciones relevantes en el sistema.

14. Continuidad de la actividad

Planes de respaldo (backup) y recuperación ante desastres.

15. Mejora continua del proceso de seguridad

Ciclo PDCA aplicado a la seguridad de la información.

Categorización de Sistemas y Dimensiones de Seguridad

La categoría de un sistema (Básico, Medio, Alto) determina la exigencia de las medidas.

Confidencialidad: La información solo es accesible por personas autorizadas. Se garantiza principalmente mediante técnicas de "Cifrado" (Criptografía).

Integridad: La información se mantiene exacta y sin alteraciones no autorizadas. Se asegura mediante el cálculo del "Hash".

Disponibilidad: Los sistemas y datos están accesibles cuando se necesitan.

Autenticidad: Garantía de que la identidad del usuario o proceso es real.

Trazabilidad: Capacidad de rastrear quién hizo qué y cuándo sobre la información. Se garantiza específicamente mediante el uso de "Sellos de tiempo" (Time stamps).

Regla de Categorización Global: Un sistema se valora en cada dimensión (Bajo/Medio/Alto). La Categoría Global del sistema será el nivel máximo alcanzado en cualquiera de sus dimensiones individuales.

Estructura de Medidas de Seguridad (Anexo II)

Las medidas se dividen en tres grandes marcos y se agrupan por familias.

1. Marco Organizativo [G]: Estrategia y política (Gobernanza).

- Familias: Política de seguridad, Normativa, Organización de la seguridad.

2. Marco Operacional [op]: Protección en la explotación diaria.

- Familias: Planificación, Control de accesos, Explotación, Gestión de incidentes, Continuidad de la actividad.

3. Marco de Protección [mp]: Medidas técnicas y físicas concretas.

- Familias: Protección de las comunicaciones, Soportes de información, Instalaciones.

Madurez y Cumplimiento: Se mide en niveles (L0 a L5). Además, se contempla el "Perfil de Cumplimiento Específico" para adecuar el ENS a sectores concretos (como el 5G).

El Esquema Nacional de Seguridad 5G (ENS5G) – RD 443/2024

El ENS5G nace del RD 443/2024 y el RDL 7/2022. Es vital conocer a los sujetos obligados y las exclusiones:

- **Sujetos Obligados:** Operadores 5G, Suministradores 5G y Usuarios Corporativos (aquellos con derechos de uso de espectro para redes privadas o autoprestación).
- **Exclusión Crítica:** No se aplica a Defensa Nacional, Seguridad Nacional ni actividades de las Fuerzas Armadas (Art. 4.2).

Elementos Críticos y Gestión de Riesgos en Redes 5G

La ley impone el control soberano sobre partes vitales de la infraestructura.

Parte de la Red	Consideración de Criticidad / Ubicación
Núcleo de la Red (Core)	Elemento Crítico. Ubicación obligatoria en Territorio Nacional.
Sistemas de Control/Gestión	Elemento Crítico. Ubicación obligatoria en Territorio Nacional.
Red de Acceso (RAN)	Elemento Crítico solo en zonas geográficas o centros específicos (Estructuras nucleares, Defensa, etc.).

Funciones de Transporte	de	Parte de la red sujeta a análisis de riesgos, pero no definida de origen como crítica global.
--------------------------------	----	---

Suministradores de Alto Riesgo y Estrategia de Diversificación

El Gobierno puede calificar proveedores como de alto riesgo basándose en criterios técnicos y estratégicos (vínculos con gobiernos de terceros países, estructura de capital, etc.).

Procedimiento de Designación (Art. 15):

1. **Inicio:** De oficio por el Ministerio para la Transformación Digital.
2. **Informes preceptivos:** CNMC, Interior, Defensa, CNI e INCIBE.
3. **Audiencia:** 15 días hábiles para alegaciones de los afectados.
4. **Resolución:** Acuerdo del Consejo de Ministros (plazo máximo 6 meses).
5. **Plazos de sustitución:** El Consejo de Ministros fijará el plazo, que en ningún caso podrá ser inferior a 1 año para elementos críticos.

Estrategia de Diversificación (Art. 17):

- **En la Red de Acceso:** Obligación de usar al menos dos suministradores diferentes.
- **Definición de "Diferentes":** No pueden pertenecer al mismo grupo de empresas según el Art. 42 del Código de Comercio.
- **Núcleo de red:** Se permite suministrador único (bajo supervisión).

Gobernanza y Respuesta a Incidentes 5G

- **SOC 5G de referencia:** Depende del Ministerio para la Transformación Digital. Apoyo operativo y monitorización en tiempo real.
- **Auditorías Bienales:** Los operadores deben someterse a auditorías ordinarias cada dos años. El informe se presenta al Ministerio.

- **INCIBE-CERT:** Entidad de referencia para respuesta a incidentes del sector privado y sujetos que no sean Sector Público (Art. 28).
- **Jerarquía de Cumplimiento Técnico (Art. 23.2.g):** Los operadores 5G deben cumplir con:
 1. **Medidas de Categoría Alta del ENS (RD 311/2022).**
 2. O el Perfil de Cumplimiento Específico que se apruebe.
 3. O la norma ISO/IEC 27002:2022 si el ENS no fuera de aplicación.

Glosario de Términos Imprescindibles

- **3GPP (3rd Generation Partnership Project):** Asociación que desarrolla los estándares técnicos globales de telefonía móvil.
- **Autoprestación:** Uso de redes y servicios 5G por una empresa para sus propios fines profesionales sin ofrecer servicio al público.
- **ENS5G:** Esquema Nacional de Seguridad de redes y servicios 5G (RD 443/2024).
- **NESAS (Network Equipment Security Assurance Scheme):** Esquema de certificación de la GSMA/3GPP que los operadores deben exigir a sus suministradores (Art. 23.2.e).
- **SCAS (Security Assurance Specification):** Especificaciones técnicas de seguridad para productos específicos de red 5G.
- **SOC (Security Operations Center):** Centro de Operaciones de Seguridad encargado de la detección y respuesta.
- **Ubicación en Territorio Nacional:** Requisito de residencia física en España para los elementos críticos de las redes públicas.
- **15 días hábiles:** Plazo legal para responder a requerimientos de información del Ministerio (Art 21.2). Su incumplimiento pasado un mes es infracción grave.
- **LUCIA:** Herramienta para la gestión de incidentes (ticketing) en entidades del ENS
- **CLAUDIA:** Motor de detección de amenazas complejas (APTs) en el puesto del usuario
- **MARIA:** Análisis de código dañino
- **EMMA:** Es la herramienta del CCN que proporciona "visibilidad y control sobre la red".

- **ADA:** Es la plataforma de "análisis avanzado de malware".
- **GLORIA:** Se define como la herramienta para la "gestión de eventos e información de seguridad (SIEM)" o para la "auditoría continua".
- **FACILITA:** Herramienta de la AEPD para ayudar a empresas con tratamientos de datos de escaso riesgo a cumplir la LOPD
- **Regla 3-2-1 de Backup:** Conservar 3 copias de seguridad, en 2 soportes diferentes y 1 copia fuera de la organización (offline/nube)
- **WAF (Web Application Firewall):** Módulo para filtrar y monitorear específicamente el tráfico HTTP hacia servidores web
- **Jerarquía de cumplimiento 5G:** Primero medidas Categoría Alta del ENS